Atomic Red Team and APT29 analysis

Weeks 9 and 10 project report

Introduction to Threat Hunting | Academic year 2026–2027

Group project: Forensic Analysis and Detection of Simulated Infostealer-Like Activity in Windows Environments

Revised 12 November 2026 | Practice instructor: Noyan Tendikov

Results and scope

On Linux, five of seven profile archive attempts succeeded and two failed to write. On Windows, nine controls yielded three archive commands followed by reads of the synthetic profile. These included tar.exe cf and an authorized backup. A subsequent Windows run exercised the six-stage Week 8 scenario and verified a loopback upload.

The APT29 analysis maps ten techniques. Volexity's July 2020 case identifies a local PST as the input to 7-Zip. The Windows artifact review also examines the group's archived PowerShell evidence and published investigations into browser passwords and cookies.

Syllabus requirement	Delivered evidence
Week 9 selected Atomic tests	Three pinned tests, native traces, outcome checks and cleanup
Week 9 SIEM analysis	Linux process hunts and nine Windows 4688/4663 controls
Week 10 APT29 or APT41 analysis	APT29 source analysis, ten mappings and a Navigator layer
Transparent increments and defense	Separate commits with real dates; a 7 minute 30 second defense outline

This report accompanies the complete Markdown documentation, scripts and machine-readable evidence in the GitHub repository. The group must perform the oral defense; no teacher evaluation or successful defense is claimed.

GitHub project and evidence

Week 9 laboratory design

The original Linux experiment used three official Atomic Red Team procedures. The Windows follow-up used built-in tar.exe, a synthetic profile and nine scenarios across short, long and traditional option forms. Both platforms used disposable training inputs.

Technique and test	GUID	Action
T1059.004 test 8	b04ed73c-7d43-4dc8-b563-a2fc595cba1a	Shell loop prints five markers
T1560.001 test 6	cde3c2af-3485-49eb-9c1f-0ed60e9cc0af	gzip compresses mock-browser.json
T1560.001 test 7	7af2b51e-ad1c-498c-aca8-d3290c19535a	tar archives the lab-browser folder

The commands were executed manually through the documented executor model, with a custom strace wrapper. Invoke-AtomicRedTeam was not used. Test numbers are recorded at source commit a0e3f9bc69fed2fd711bd1f1aa87a40c33482fe6; GUIDs and YAML file hashes make the selection traceable even if upstream ordering changes.

All inputs are generated training data. The folder contains a fake browser credential record and an invalid session token. The gzip output remains present until after the tar test, so the tar member list also contains that earlier compressed file. No browser profile, DPAPI store, valid token, external receiver or persistence mechanism is involved.

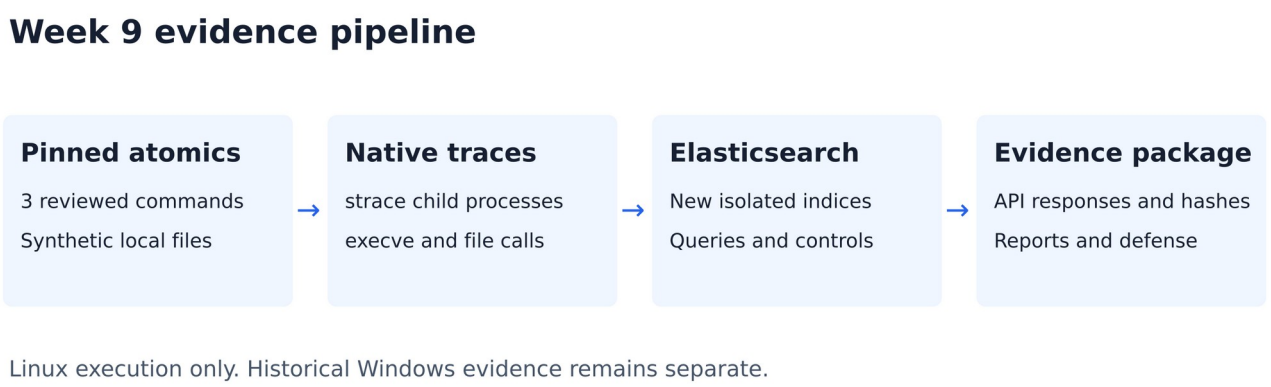


Figure 1. Evidence collection and analysis workflow. Original diagram, not a tool screenshot.

The collector traces only its child processes. The resulting events are labelled lab.strace and host.name is the fixed pseudonym LAB-LINUX. They are not Sysmon, Windows Security events or system-wide endpoint telemetry.

Original execution evidence from 8 November

Case	Exit code	execve events	Outcome
atomic_shell	0	7	Verified markers
atomic_gzip	0	2	Verified archive
atomic_tar	0	4	Verified archive
benign_backup	0	4	Benign control
plain_control	0	1	Benign control

The raw strace files preserve successful execve calls and file operations. Each normalized event records the originating trace filename and line number. Failed PATH lookups are excluded. Five parser/provenance tests cover successful launches, failed lookups, file-only calls, escaped arguments and reconstruction of every archived event.

The shell test produced all five expected marker lines. Decompressing the gzip file reproduced the exact mock-browser bytes. Reading the expected tar members reproduced the source browser and cookie files. SHA-256 values were saved before the generated archives were removed by cleanup. Synthetic inputs, output streams, traces and outcome records remain in the evidence directory.

Collection interval: 8 November 2026, 14:59:56–15:00:01 UTC, equivalent to 19:59:56–20:00:01 in Asia/Almaty. These are actual execution times, not assigned week dates.

Run ID: 20261108T145956001720Z

Reproducible commands

```
python3 scripts/collect_week9_atomics.py
```

```
python3 scripts/analyze_week9_elastic.py evidence/week9/<NEW_RUN_ID>
```

```
python3 -m unittest discover -s tests -v
```

Start the dedicated Elasticsearch instance first using config/week9-elasticsearch.yml. The full Markdown runbook gives the verified archive version, loopback ports, Kibana data-view setup and preservation rules. Each new collection has a unique directory and index; the analyzer refuses to overwrite an existing run.

Published source hashes permit byte-integrity checks. They establish consistency of the retained artifacts, not independent certification of the lab or production detection accuracy.

Original SIEM results from 8 November

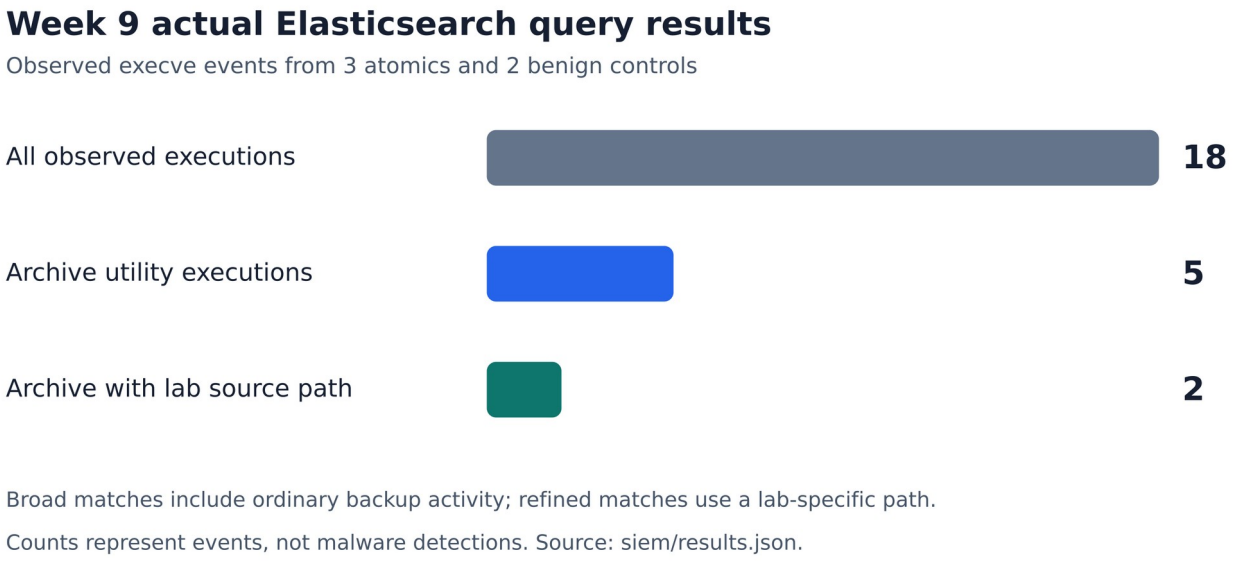


Figure 2. Counts calculated from the saved Elasticsearch responses.

The broad query selects process.name equal to tar or gzip within lab.strace. It excludes shell wrapper events even when their command strings mention an archiver. The refined query additionally requires an argument containing lab-browser. Neither query selects on case labels, expected outcomes or Atomic test IDs.

In the original five-case run, the refined query selected the two actual profile archives. The expanded experiment on the next page tests whether this interpretation holds when the marker appears only in the output name or a listing command.

The original search matched a substring anywhere in the argument list. The final query combines creation mode, a same-process open of a registered input and the archiver’s exit status.

Validation	Result
Collection versus ingestion count	Matched
Expected refined cases	atomic_gzip and atomic_tar
Separate boundary fixtures	10 synthetic documents; 20 assertions passed
Archive integrity and cleanup	Passed

Elasticsearch and Kibana run as a separate loopback-only teaching instance. This increment implements custom collection and hunting in Elastic; it does not configure an Elastic Security integration or scheduled alerts. Use the archived UTC time range when demonstrating the observations.

Archive creation and write failures

15 scenarios, 43 process executions and 18 tar/gzip launches. Seven archiver processes opened a registered training input in create mode. Five exited 0 and two exited 2. All 60 expected case-level query counts matched the live Elasticsearch responses.

Control	Attempt / exit 0 / failed	Independent evidence
Atomic gzip and tar	1 / 1 / 0 each	The original profile bytes were recovered from each output.
Backup of renamed profile	1 / 1 / 0	Both source members matched.
--file=out/long.tar	1 / 1 / 0	Long-form creation succeeded. Both members matched.
--file out/separate.tar.gz	1 / 1 / 0	Reordered long options and gzip compression succeeded.
List or extract archive	0 / 0 / 0 each	Long-form listing and extraction exited normally.
Short or long write to /dev/full	1 / 0 / 1 each	Both writers received ENOSPC and exited 2.
Other negative controls	0 / 0 / 0 each	Six cases: shell atomic, ordinary backup, plain shell, destination-only backup, short listing and decompression.

Follow the evidence in one PID

The collector identifies the synthetic inputs before execution. The analyzer reads the archive mode from the command line and the input path from a successful read-only open. Its attempt query requires both. The success and failure queries add the native exit code of the same process image. Missing exit evidence leaves the attempt unclassified.

In the long-option failure trace, lines 12–13 show source opens, line 14 shows the failed write and line 22 records exit 2. In the successful long-option controls, the utility exited 0 and the archived members matched the expected bytes. Legitimate backups can meet the same conditions.

Fifteen executed cases and their Elasticsearch results

Native tar trace for a failed long-option write

Week 9 Windows archive controls

Windows Server 2022 Datacenter Evaluation, build 20348 | 12 November 2026, 02:08 Almaty

Windows recorded 9 process starts (4688) and 19 file-access events (4663) for nine controls. In Elasticsearch 9.5.5 the same XML produced 2 correlated pairs using the earlier parser and 3 after recognizing cf in the first argument.

Scenario	Qualifying native record IDs	Expected / observed pair
Short-form profile archive	4688 #513, 4663 #516	Yes / Yes
Ordinary backup	4688 #526	No / No
Profile in output name	4688 #539	No / No
List existing archive	Neither predicate matched	No / No
Authorized backup	4688 #554, 4663 #557	Yes / Yes
List raw profile JSON	4663 #568	No / No
cf on profile	4688 #569, 4663 #571	Yes / Yes
tf on archive	Neither predicate matched	No / No
tf on raw profile JSON	4663 #581	No / No

Traditional creation and listing

Record 569 shows PID 2000 launching tar.exe cf. Record 571 shows the same process and logon reading profile\cookies.json 10.3 ms later. The archive member matched the input SHA-256. The tf command successfully listed that member.

Running tf on the raw JSON also produced a profile read (record 581), then exited 1. Both tf controls stayed outside the EQL sequence. All nine case results matched the manifest. The authorized backup illustrates why the rule also finds legitimate activity.

Windows run · Security XML · EQL request and response

Week 10 APT29 case analysis

APT29 is the selected group. MITRE identifies it as G0016 and links it to Russia's SVR. SolarWinds is the main case; the later StellarParticle investigations are identified separately. Attribution is reported intelligence, not a conclusion drawn from our local test results. [1, 2]

FireEye's December 2020 report describes SUNBURST delivery through compromised SolarWinds Orion updates. Its May 2022 attribution update associates the original UNC2452 activity with APT29. The investigation also reports temporary scheduled-task modifications followed by restoration. [3]

Microsoft's January 2021 investigation describes archiving with 7-Zip, including password-protected and split archives. This is the direct behavioral bridge to our tar/gzip exercise, while the operating system, utility and additional options differ. [4]

CrowdStrike's January 2022 StellarParticle report includes investigations extending into 2021. It reports Chrome profile and DPAPI material being accessed for cookies, as well as evidence of saved-password export. These observations are relevant to infostealers but must not be collapsed into a universal sequence for every Orion compromise. [5]

APT29 selected techniques and project evidence

Source-backed CTI is separate from laboratory validation

ATT&CK	Technique	Project evidence
T1195.002	Compromise Software Supply Chain	CTI only / not validated
T1059.001	PowerShell	Historical Windows lab
T1059.003	Windows Command Shell	CTI only / not validated
T1053.005	Scheduled Task	CTI only / not validated
T1555.003	Credentials from Web Browsers	CTI only / not validated
T1539	Steal Web Session Cookie	CTI only / not validated
T1005	Data from Local System	CTI only / not validated
T1560.001	Archive via Utility	Linux and Windows archive tests
T1074.002	Remote Data Staging	CTI only / not validated
T1048.002	Asymmetric encrypted non-C2 exfiltration	CTI only / not validated

ATT&CK v20.1 checked 8 Nov 2026. Colors are evidence labels, not detection scores.

Figure 3. Ten selected mappings. Evidence categories are not coverage scores.

ATT&CK v20.1 was current on 8 November 2026. The Navigator layer identifies major version 20 and retains evidence-status comments. Its colors distinguish CTI-only items, historical Windows work and the Linux and Windows archive tests. [6]

Week 10 mapping and hunt priorities

ATT&CK	Observed behavior in sources	Project implication
T1195.002	Trojanized software updates [3]	Delivery context only
T1059.001 / .003	PowerShell and cmd activity [2]	Earlier Windows evidence stays historical
T1053.005	Temporary task modification [3]	Collect task changes in a future VM run
T1555.003	Saved browser-password export [5]	Mock JSON does not test credential access
T1539	Browser cookie theft [5]	Fake cookies do not prove session theft
T1005	Local PST supplied to 7-Zip [9]	Check a PST read by the archiver process
T1560.001	7-Zip archive creation [4]	Linux tar/gzip and Windows tar.exe tests
T1074.002	Archives on an OWA server [2]	Local output is not remote staging
T1048.002	MITRE maps HTTPS retrieval [2]. Volexity illustrates the URL [9].	Seek IIS response status and bytes served

Volexity documented the mailbox export and 7-Zip input C:\Temp\b.pst. The PST supports T1005. Compression supports T1560.001, and placing Redir.png under the OWA web directory supports staging. [9]

What supports T1048.002?

MITRE C0024 classifies retrieval of the staged archive over HTTPS as T1048.002 and cites Volexity. Volexity reports email exfiltration, shows the 7-Zip command and gives an example HTTPS URL. It publishes no web log, response status or transferred byte count for that URL. Our Windows lab observed local archiving. [2, 9]

Remaining hunt priorities

The first Windows dataset covers tar.exe on one host. The later six-stage run covers local staging, Compress-Archive and an HTTP POST to loopback. Remote staging, session reuse and external egress would require separate evidence.

Process creation and file-created events alone do not demonstrate file reads. A local archive does not establish exfiltration. A plaintext mock record does not test browser credential decryption. The Unix shell test is T1059.004 and is not relabelled PowerShell or attributed to APT29.

Transparency and defense

The original increments were committed on 8 November. The 12 November revisions added Linux failure controls, Windows archive evidence and a source comparison for the Exchange case. The timed guide covers both platforms. The later full-chain run is dated separately below.

Windows evidence for execution and browser access

Local PowerShell execution on 22 October

Event 400 record 28101 identifies PID 12292 and engine startup at 11:17:22.8355311 UTC. A CIM sample at 11:17:22.9908514 UTC identifies powershell.exe and its parent pwsh.exe (PID 2732). A run-specific stdout marker and identical SHA-256 values for the source and staged mock files corroborate the local copy. File access and identity activity require separate sensors.

Group evidence: native PowerShell event

Published StellarParticle investigation

T1555.003. RDP Bitmap Cache reconstruction displayed Chrome exporting saved passwords to a plaintext CSV. This supports an export in the observed session. Further evidence would be needed to determine subsequent use of that file.

T1539. Shellbags documented navigation through Chrome and DPAPI directories. A Falcon NewScriptWritten event identified the Cookie Editor extension. The investigators correlated these artifacts with session impersonation and assessed offline decryption as likely. Directory navigation alone cannot establish a copy or successful reuse.

CrowdStrike investigation, figures 2–4

Windows Security audit on 12 November

The Week 9 native Windows run linked 4688 NewProcessId with 4663 ProcessId, host, logon and event order. The nine controls appear on the Windows archive page. A positive read needs both the registered input file and ReadData access mask bit 0x1.

Microsoft documentation for file access auditing (4663)

Microsoft documentation for process creation (4688)

Sources and deliverable guide

[1] MITRE ATT&CK APT29 group G0016

Live profile checked 2026-11-08. Accessed 8 November 2026.

[2] MITRE ATT&CK SolarWinds Compromise C0024

Live profile checked 2026-11-08. Accessed 8 November 2026.

[3] FireEye Mandiant SolarWinds supply chain investigation

2020-12-13; attribution update May 2022. Accessed 8 November 2026.

[4] Microsoft Solorigate second-stage investigation

2021-01-20. Accessed 8 November 2026.

[5] CrowdStrike Observations from the StellarParticle Campaign

2022-01-27; includes investigations extending into 2021. Accessed 8 November 2026.

[6] MITRE ATT&CK version history

v20.1 current when checked 2026-11-08. Accessed 8 November 2026.

[7] Atomic Red Team pinned source

[8] Syllabus 2026–2027 section 3.3

The syllabus file was read locally and checked against the authenticated LMS folder. Only a paraphrase of the relevant requirements is included; the course document is not republished.

[9] Volexity · Dark Halo and the SolarWinds compromise, 14 December 2020

Repository material	Purpose
docs/week9-atomic-red-team.md	Practical report and full reproduction guide
docs/week10-apt29-analysis.md	Source-qualified analysis and links
docs/weeks9-10-defense.md	Timed script and rehearsal questions
evidence/week9/<RUN_ID>/	Native traces, collection checks and SIEM evidence
data/week9/ and data/week10/	Pinned tests, source register and ATT&CK mapping

AI assistance: OpenAI Codex assisted with research, mapping, code, lab execution, verification and writing. The group should review and understand the work and follow the instructor’s AI-permission and disclosure requirements. This document does not assert that instructor permission was granted.

Windows execution of the Week 8 plan

Run c5dff010b214 on Microsoft Windows Server 2022 Datacenter Evaluation build 20348. This follow-up exercised all six planned stages with four generated files. The original Week 9 tar.exe controls and the Week 10 APT29 source analysis retain their own datasets.

From the training page to a scheduled task

The operator copied the command shown by the loopback training page viewer and pasted it into the guest. Security 4688 records 488 and 490 show cmd.exe starting the PowerShell loader, PID 3936. The loader decoded a fixed marker. Security 4698 record 507 contains a logon trigger. The operator's scenario ran the task on demand and verified its marker. Security 4699 record 524 records deletion.

From file discovery to the receiver

The loader launched hostname.exe and whoami.exe, enumerated the synthetic profile, read four files and staged them. Security 4663 records include 515. PowerShell 4104 includes Compress-Archive. The receiver recorded HTTP 201 for POST /receive on 127.0.0.1. Its 578-byte ZIP matched the sender's SHA-256. Independent extraction recovered all four expected members.

SHA-256 eeed7a4baa02fff7fbc50ba55b265fea3257121bd8b168b1d23bf55c5a8bdebf

Controls and interpretation

Elasticsearch indexed 26 native events and 3 receiver entries. The directory-listing control returned four names and zero content-read matches for those files. A POST to an invalid route returned 404 and stored zero bytes. The VM cleanup removed the task and scratch files and stopped the listener.

The local HTTP upload models T1048.003. The separate APT29 mapping T1048.002 comes from MITRE C0024 and its cited Volexity investigation. The experiment used synthetic data and a guest with no network adapter.

Run report and evidence • Elasticsearch checks